



VULNERABILITY ASSESSMENT REPORT

FOR [REDACTED]



Table of Contents

1 SUMMARY OF VULNERABILITY ASSESSMENT 2

1.1 IMPLEMENTATION 2

1.2 IDENTIFIED PROBLEMS..... 2

1.3 CATEGORIZATION OF OBSERVATIONS..... 3

1.4 COMPILATION OF WEB APPLICATION OBSERVATIONS 3

2 WEB-APPLICATION OBSERVATIONS 4

2.1 B-2025-01: CROSS-SITE REQUEST FORGERY (CSRF) VULNERABILITY 4

2.1.1 Observation and impact 4

2.1.2 Explanation..... 4

2.1.3 Identified on 5

2.1.4 Recommendations..... 5

2.2 -2025-02: MISSING SECURITY HEADERS..... 6

2.2.1 Observation and impact 6

2.2.2 Explanation..... 6

2.2.3 Identified on 7

2.2.4 Recommendations..... 7

2.3 -2025-03: ACTIVE MIXED CONTENT OVER HTTPS. 8

2.3.1 Observation and impact 8

2.3.2 Explanation..... 8

2.3.3 Identified on 8

2.3.4 Recommendations..... 8

2.4 -2025-04: COOKIE SECURITY ISSUES..... 9

2.4.1 Observation and impact 9

2.4.2 Explanation..... 9

2.4.3 Identified on 9

2.4.4 Recommendations..... 9

2.5 -2025-05: OUTDATED AND VULNERABLE JQUERY LIBRARIES..... 10

2.5.1 Observation and impact 10

2.5.2 Explanation..... 10

2.5.3 Identified on 10

2.5.4 Recommendations..... 10

2.6 -2025-06: HTTP STRICT TRANSPORT SECURITY (HSTS) MISCONFIGURATION. 11

2.6.1 Observation and impact 11

2.6.2 Explanation..... 11

2.6.3 Identified on 11

2.6.4 Recommendations..... 11

3 ASSUMPTIONS AND LIMITATIONS 12



1 Summary of Vulnerability assessment

1.1 Implementation

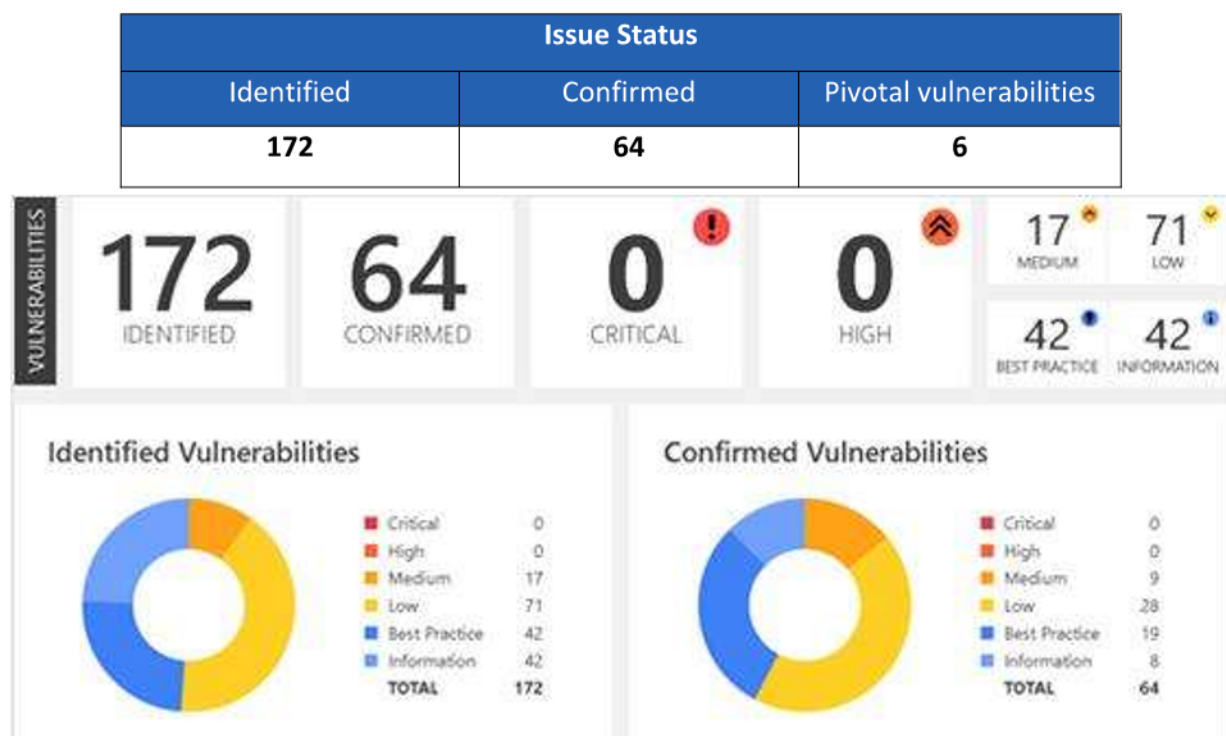
Evaluation type: Web Application
Initial review period: 2025/03/12 to 2025/03/19
WEB: [REDACTED]

1.2 Identified problems

This report details the findings and recommendations arising from the Web Application Security Review in determining possible security weaknesses that may exist within their current infrastructure.

There were total of **172** findings identified during the initial review. The following segments represent the breakdown of the risk levels, and the security rating identified after the initial testing.

By addressing the following pivotal vulnerabilities, all identified vulnerabilities can be effectively mitigated.



1.3 Categorization of observations

The observations are categorized based on their potential impact (harm caused) and probability (probability of detection and exploitation), as well as whether they pertain to web application vulnerabilities.

Category based on Impact and probability

- **Critical and high impact issues** - Pose the biggest and most immediate threat and should be prioritized and addressed as soon as possible.
- **Medium impact issues** - Exhibit a varying threat level ranging from low to high, therefore priority should be given based on its CVSS score. Medium-sized issues with high CVSS scores should be addressed the same as how high issues are handled.
- **Low impact issues** - Can be given the lowest priority because they are very difficult to exploit and therefore pose a very small threat.

Category based on type

- **Web application vulnerabilities** - These vulnerabilities are associated with the web application's functionality, design, or implementation. Examples include SQL injection, cross-site scripting (XSS), improper access control, and insecure file uploads. Such issues can compromise the integrity, availability, or confidentiality of the application and its data.

1.4 Compilation of WEB Application observations

Issue ID	Vulnerability	Severity	Status
BLZ-WEB-2025-01	Cross-Site Request Forgery (CSRF) Vulnerability	Medium	New
BLZ-WEB-2025-02	Missing Security Headers	Medium	New
BLZ-WEB-2025-03	Active Mixed Content over HTTPS	Medium	New
BLZ-WEB-2025-04	Cookie Security Issues	Medium	New
BLZ-WEB-2025-05	Outdated and Vulnerable Libraries	Medium	New
BLZ-WEB-2025-06	HTTP Strict Transport Security (HSTS) Misconfiguration	Low	New

2 Web-Application Observations

Below are the issues found by the Web Application Security Review. The issues are organized by priority and category and broken down by the package, namespace, or location in which they occur.

The priority of an issue can be Critical, High, Medium, Low or Info.

2.1 BLZ-WEB-2025-01: Cross-Site Request Forgery (CSRF) Vulnerability

CVSS Score:	6.3
Severity:	MEDIUM
Vector String:	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:H/A:N
Threat:	Unauthorized state-changing actions without user consent
Root Cause:	Lack of CSRF token validation and improper request origin checks

2.1.1 Observation and impact

A potential CSRF vulnerability was observed on multiple endpoints where sensitive actions can be executed without proper CSRF token validation. Attackers could trick users into executing unintended actions on authenticated sessions.

Impact includes:

- Unauthorized fund transfers.
- Unintended account modifications.
- Potential account takeovers if combined with other exploits.

2.1.2 Explanation

CSRF vulnerabilities arise when an attacker tricks a victim into making an unintended request using their active session without their consent. The application does not validate the origin of the request properly, allowing unauthorized actions.



2.1.3 Identified on

- [Redacted]
- [Redacted]
- [Redacted]

2.1.4 Recommendations

- Implement CSRF tokens for all state-changing operations.
- Set SameSite=Strict for session cookies.
- Validate the Origin/Referer headers.

2.2 BLZ-WEB-2025-02: Missing Security Headers.

CVSS Score:	6.3
Severity:	MEDIUM
Vector String:	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:H/A:N
Threat:	Clickjacking, MIME-type sniffing, and content injection attacks
Root Cause:	Absence of essential security headers

2.2.1 Observation and impact

Multiple security headers were found missing, increasing exposure to attacks such as clickjacking, MIME-type sniffing, and unauthorized script execution.

Impact includes:

- Clickjacking attacks exploiting missing X-Frame-Options.
- Potential execution of malicious JavaScript due to lack of Content-Security-Policy (CSP).
- MIME-type sniffing vulnerabilities due to missing X-Content-Type-Options.

2.2.2 Explanation

Security headers protect applications from various web-based attacks. Without proper headers, an application is vulnerable to script injections, content manipulation, and data exposure.

2.2.3 Identified on

- [REDACTED] Missing X-Frame-Options, CSP, X-Content-Type-Options)
- [REDACTED]
- [REDACTED]

2.2.4 Recommendations

- Enforce Content-Security-Policy to limit script sources.
- Implement X-Frame-Options: SAMEORIGIN to prevent clickjacking.
- Set X-Content-Type-Options: nosniff to prevent MIME-type sniffing.

2.3 BLZ-WEB-2025-03: Active Mixed Content over HTTPS.

CVSS Score:	5.7
Severity:	MEDIUM
Vector String:	CVSS:3.1/AV:N/AC:L/PR:H/UI:R/S:U/C:L/I:L/A:H
Threat:	Man-in-the-Middle (MITM) attacks and data interception
Root Cause:	Loading insecure HTTP resources on HTTPS pages

2.3.1 Observation and impact

Mixed content errors occur when a secure website loads resources over an insecure connection, making it vulnerable to MITM (Man-in-the-Middle) attacks.

Impact includes:

- Data interception by attackers.
- Content injection altering page behavior.
- Possible browser warnings reducing trustworthiness.

2.3.2 Explanation

When HTTPS pages load HTTP resources, attackers can intercept and manipulate the unencrypted traffic, leading to security risks.

2.3.3 Identified on

- [REDACTED]
- P [REDACTED]
- [REDACTED]

2.3.4 Recommendations

- Ensure all resources are loaded securely over HTTPS.
- Update links to enforce HTTPS connections.

2.4 BLZ-WEB-2025-04: Cookie Security Issues.

CVSS Score:	4.8
Severity:	MEDIUM
Vector String:	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
Threat:	Session hijacking and XSS exploitation
Root Cause:	Cookies lack Secure, HttpOnly, and SameSite attributes

2.4.1 Observation and impact

Cookies are not marked as HttpOnly or Secure, making them vulnerable to attacks such as session hijacking and cross-site scripting.

Impact includes:

- Exposure of session cookies to JavaScript-based attacks.
- Increased risk of unauthorized session takeover.

2.4.2 Explanation

Without secure flags, cookies can be accessed via JavaScript, making them susceptible to theft via XSS attacks.

2.4.3 Identified on

- [REDACTED]
- G [REDACTED] / 1/ banking
- [REDACTED]

2.4.4 Recommendations

- Set HttpOnly and Secure flags on all cookies.
- Enable SameSite=Strict to prevent CSRF attacks.

2.5 BLZ-WEB-2025-05: Outdated and Vulnerable jQuery Libraries

CVSS Score:	4.8
Severity:	MEDIUM
Vector String:	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
Threat:	Exploitation of known vulnerabilities in outdated libraries
Root Cause:	Use of outdated jQuery versions with known security flaws

2.5.1 Observation and impact

The application uses outdated versions of jQuery, which have known vulnerabilities.

Impact includes:

- Potential execution of malicious JavaScript code.
- Increased exposure to publicly known exploits.

2.5.2 Explanation

Outdated libraries can contain known security flaws that attackers exploit to compromise the application.

2.5.3 Identified on

- [REDACTED]
- [REDACTED]

2.5.4 Recommendations

- Update jQuery to the latest stable versions.
- Use a Content Security Policy (CSP) to mitigate risks.

2.6 BLZ-WEB-2025-06: HTTP Strict Transport Security (HSTS) Misconfiguration.

CVSS Score:	3.3
Severity:	LOW
Vector String:	CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:N
Threat:	HTTPS downgrade attacks and potential MITM threats
Root Cause:	HSTS max-age value set too low, allowing fallback to HTTP

2.6.1 Observation and impact

The HSTS max-age value is too low, potentially allowing downgrade attacks.

Impact includes:

- Users may unknowingly access an insecure HTTP version of the site.
- Increased risk of MITM attacks.

2.6.2 Explanation

HSTS ensures that browsers enforce HTTPS connections. A low max-age value weakens security by allowing connections to default to HTTP.

2.6.3 Identified on

- [REDACTED]

2.6.4 Recommendations

- Increase max-age for HSTS to enforce HTTPS strictly.

3 Assumptions and limitations

The following assumptions have been made, and listed limitations apply:

- The review was limited to the current version of systems that were running at the time of review.
- Denial of Service (DoS) attacks were not carried out as part of the scope of work.
- Our reports provide an indication of the majority of risks related to the systems/hosts. However, it does not provide total assurance on coverage of all risks related to the systems/hosts reviewed. Further, in relation to infrastructure weaknesses, we only state risks and vulnerabilities known and published by the applicable systems vendor as of the review date.
- A vulnerability assessment/penetration testing assessment does not provide absolute assurance that the target host is protected against all vulnerabilities. Therefore, our assessment report shall include only the findings identified during our review. New vulnerabilities in components and systems are identified daily.
- All documents are subject to the existing IS and business environment as of the date of the submission of the final deliverables. Any changes made to the systems or underlying controls, any process-related changes, any changes in the security policy or procedures, adoption of any new technology, or a new service line may introduce new information security risks, which shall make our deliveries invalid. We have no obligation to update our report on events that have occurred after the issue date of our reports.